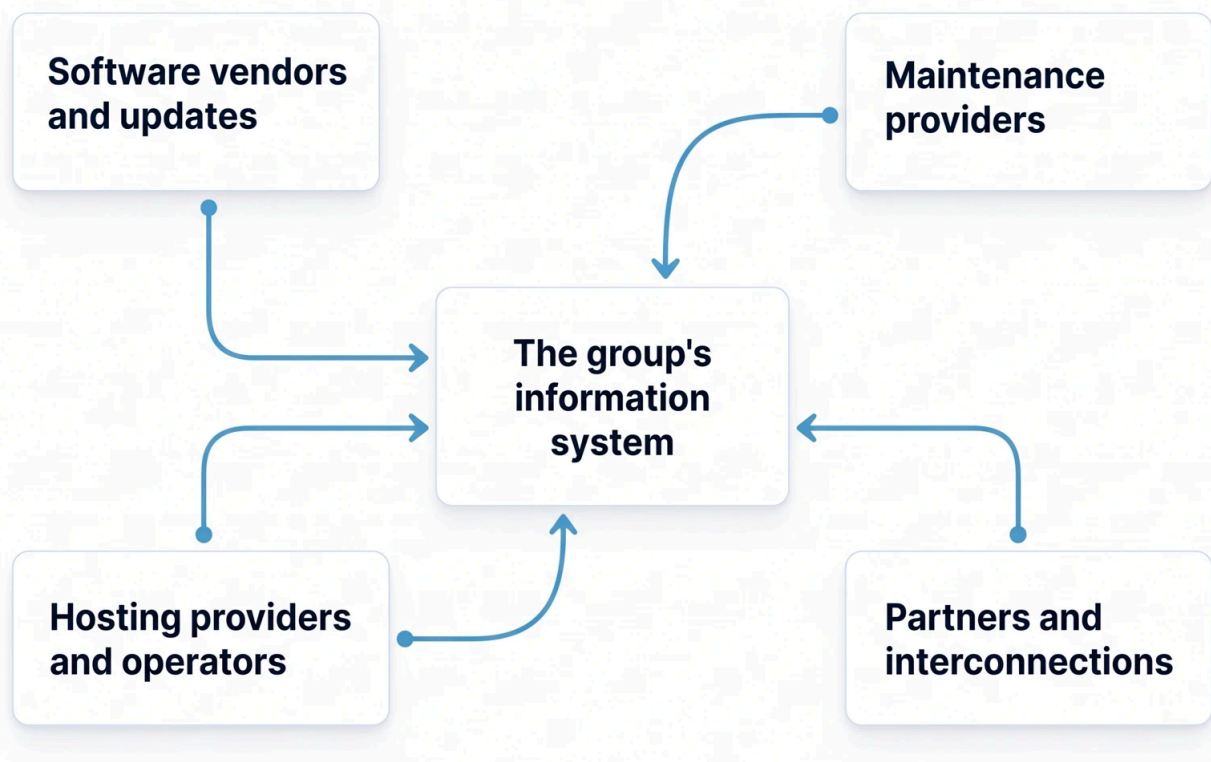


The CISO's Desk: Supply Chain Attack

✓ The question that comes in through the suppliers' door



Every link already holds access

Session objectives

By the end of this sequence:

- **Explain** what the supply chain of an information system is and why it has become a leading attack vector
- **Distinguish** a direct attack from a pivot attack, and say what that distinction changes for the defense
- **Identify** the MERIDIAN group's third-party risk from the mapping built in session 2, without waiting for any additional tool or method
- **Prepare** a quarterly management briefing that answers a media-driven worry with sourced facts and a decision to be made

Prerequisites

- The ecosystem view from the session 2 mapping: the parties the information system of the subsidiary under review interacts with, read in §3 and §6 of the subsidiary pack. It is this morning's working material.
- The business assets and supporting assets per subsidiary (session 2), and the Top 5 critical assets.
- The governance established in session 1: the quarterly "CISO (chief information security officer) briefing" presented to the Executive Committee, and the Group CISO's position as arbiter of cross-subsidiary conflicts.
- The risk assessment begun in session 5: the framing, the security baseline and the risk origin / target objective pairs of the D5 file.

What to know before the exercise

Three notions are enough to handle this morning's case. The rest of the day will equip them, but the reasoning itself can be conducted right now with the mapping.

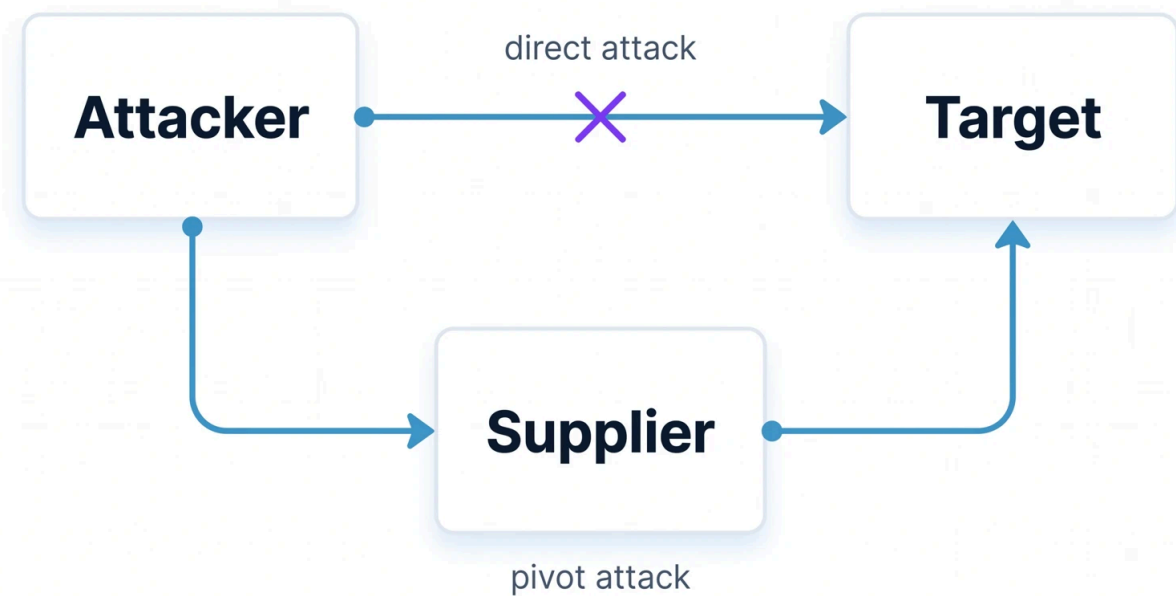
First, the problem. Since session 1, everything that has been protected belonged to the group: its networks, its applications, its data. Yet an organization produces almost nothing alone. It buys software and its updates, entrusts its maintenance to service providers, exposes interfaces to its customers and partners, depends on hosting providers and carriers. **The supply chain** of an information system is that whole set of suppliers, service providers and inbound flows the information system depends on to function: hardware, software, updates, services, maintenance. Its risk mechanics fit in one sentence: each link has, by construction, an access to or an influence over the organization's information system that an outside attacker will never have, and compromising the link amounts to inheriting that access. Its limit as a concept: it cannot be seen on an organization chart, because most of these dependencies are contracted by the business lines, subsidiary by subsidiary, without going through the CISO.

Two real cases fix the ideas, and they will serve all day. The first: NotPetya, the destructive malware that appeared on 27 June 2017. The CISA (the United States cybersecurity agency) alert page documents its distribution mechanism: the update of a Ukrainian tax accounting software, M.E.Doc, whose vendor environment had been compromised. The victims were not hacked one by one: they installed, in good faith, the update of a legitimate piece of software. Among the best documented collateral damage, the shipping company A.P. Moller-Maersk put a figure, in its financial communication, of a 250-300 million dollar impact on its Transport & Logistique activities in the third quarter of 2017.

Maersk was not the target: it was a customer of the wrong software, at the wrong time. The second case: SolarWinds. The joint statement by the FBI, CISA, ODNI (the Office of the Director of National Intelligence) and NSA puts at about 18,000 the number of public and private customers of the SolarWinds Orion product that received the booby-trapped update of this monitoring tool, in the campaign discovered in December 2020, with a much smaller number subsequently subjected to attacker activity. The asymmetry to remember: a single compromise at the vendor, thousands of organizations touched, and the attacker then picks its real targets from the lot.

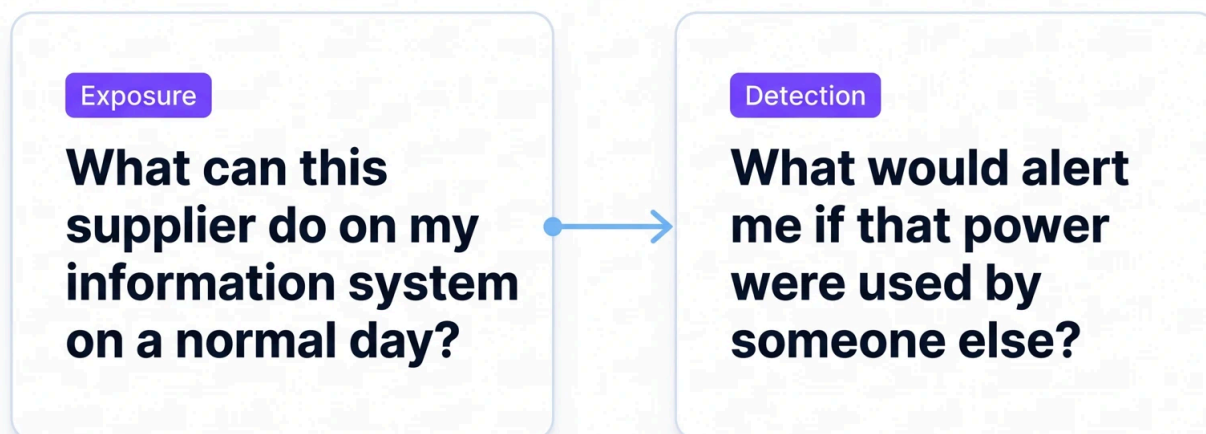


The pivot attack, next. It is the operating mode that exploits this reality: rather than attacking a well-defended target head-on, the attacker first compromises an actor that holds legitimate access to it, then “pivots” from that actor. The pivot can go through software (the booby-trapped updates of NotPetya and SolarWinds), through a service provider (the remote maintenance account that gets in without a strong password), or through an interconnection (the partner whose network touches the organization's). The attacker's logic is a logic of least effort: why force an armored door when a supplier holds its key and protects it less well? The notion's limit: “pivot” describes the path, not the severity; a pivot can end in a minor data theft as well as in a complete production shutdown.



Third-party risk, finally, is the governance translation: it is the share of risk that arises with actors the organization does not directly control, but whose presence in its system it has accepted, by contract or by usage. It is managed, not eliminated: giving up all third parties would mean bringing everything back in-house, which no management team will fund. And it is already measured: according to the CESIN (the French club of information security experts) barometer published in 2026, 35% of the significant cyberattacks suffered by companies came through indirect attacks via third parties, making it the third entry vector. That figure is the opening piece for the Executive Committee: the subject is neither theoretical nor marginal.

💡 A method reflex: when an incident "at a supplier" is reported, always ask the two questions in this order: what can this supplier do on my information system in normal times (access, flows, updates)? And what would alert me if that power were used by someone else? The first question measures the exposure, the second the detection capability. An empty answer to the second is already a finding.



An empty answer to the second is already a finding

Case study: the quarterly briefing under media pressure

Scenario and problem statement

The quarterly "CISO briefing" to the Executive Committee takes place on Thursday. On Sunday evening, the Chief Executive Officer forwards to the Group CISO a press investigation devoted to supply chain attacks, with this message: "What happened to the customers of that accounting software, can it happen to us through one of our service providers? I want your Thursday briefing to start with the answer."

The Group CISO has neither the time nor the need to launch a new study before Thursday: they have the session 2 mapping, including the ecosystem view, and the findings already established in the module. Here are four of them, well known. At MERIDIAN Logistique, the WMS (warehouse management system) TPAM (third-party application maintenance) provider, that is, the third-party application maintenance provider of the warehouse management system, operates with a shared domain account, and nobody knows how many people use it (Logistique pack \$5).

Between Logistique and Santé, the emergency replenishment API (application programming interface), on a dedicated VLAN (virtual local area network) with an inspection firewall, used to link the warehouse handheld scanners to the Santé subsidiary's pharmaceutical stock management system; the flow has been cut for three months at the request of the Santé subsidiary CISO, and the Chief Pharmacist is asking for it to resume (\$6 of

both packs). At MERIDIAN Éducation, the portal of the 45,000 accounts is hosted by an outsourcer that entrusts the backup to a second-tier subcontractor absent from the contract, and eleven subscriptions to online services escape the inventory, on limited means (§2 and §4). At MERIDIAN Territoires, the citizen services platform serves some thirty client local authorities, its logs are kept locally, and the street furniture outsourcer holds the transaction encryption keys (§2 and §4).

This morning's task: prepare the "supply chain" part of Thursday's briefing. Not a lecture to management, an answer: where is the group exposed, what is already known about it, what is the Group CISO asking for.

Guided questions

1. **Inventory** the third-party dependencies of the subsidiary under review, read in §3 and §6 of its subsidiary pack, plus the group-level dependencies of §5 of the reference pack: build a four-column table (third party or inbound flow, subsidiary concerned, nature of the access or dependency, what it can reach). Lean on the session 2 ecosystem view and on the four findings in the brief; do not stop at contracted providers, a software update flow is also a dependency.
2. **Qualify** each row of the table in one sentence: what would make it an attractive pivot path for an attacker? Reason in least-effort logic, from the attacker's point of view.
3. **Transpose** the two cases from the presentation onto the group: for the "booby-trapped software update" mechanism, designate the place in the group that most resembles it; for the "diverted maintenance access" mechanism, do the same. Justify each choice with an element from the file, not with an intuition. For each of the two mechanisms, name the contractual clause that would have helped.
4. **Draft** the three messages of Thursday's briefing: a sourced fact that frames the subject, an honest sentence on the group's exposure, a decision requested from the Executive Committee. Constraint: nothing asserted may go beyond what the material proves.
5. **Formulate** what this morning's analysis cannot do yet: what is missing to go from "here are our dependencies" to "here are the ones that must be treated first"?

Working method

Allow 10 minutes for questions 1 and 2, the qualification of question 2 fitting in a column of the table of question 1; 10 minutes for question 3; 10 minutes for questions 4 and 5, question 5 fitting in two sentences. Work from the session 2 documents, not from memory: the exercise also measures the ability to reuse the mapping as an asset, which it is. For question 4, write the sentences as they would be spoken: an Executive Committee does not listen to generalities, it listens to commitments. The answer is a written, individual page, filed in the session 6 folder; it is marked out of 10 according to the answer key's scale.



Answer keys and assessment criteria – cliquer pour révéler